Gabs440: security audit report

Created on 08 November 2026 @ 03:39 SmartTennis - TOBIAS

Gabs440 wants to build trust by giving you insight in how it builds software in a secure manner. The report details how software development at Gabs440 is being monitored and safeguarded from the developer's computer all the way to the infrastructure used for delivery.

This security report has been generated by Aikido Security based on real-time monitoring of Gabs440 code and infrastructure.

Assets in report scope

Repositories

- Projeto12

OWASP Top 10

This section details the OWASP risks for which the organization currently has active measures against.

Code	Title	Taken measures
A01:2025	Broken access control	✓ Application is properly configured ✓ Prevents unauthorized access to resources ✓ App protected against SSRF attack opportunities
A02:2025	Security misconfiguration	✓ Application is properly configured
A03:2025	Software Supply Chain Failures	✓ Not affected by malware issues
A04:2025	Cryptographic failures	✓ Enforces encryption of data at rest ✓ Enforces the use of secure connections ✓ Prevents the exposure of secret keys
A05:2025	Injection	✓ App scanned for SQL injection attack ✓ Prevents remote code execution ✓ Prevents CSRF attacks ✓ Prevents Cross Site Scripting (XSS) ✓ Prevents command injection
A06:2025	Insecure design	Monitoring, not fully compliant
A07:2025	Authentication Failures	✓ Prevents bypassing authorization controls ✓ Prevents improper certificate validation
A08:2025	Software or Data Integrity Failures	✓ Code repositories use lockfiles to pin dependencies ✓ Takes measures to ensure proper deserialization
A09:2025	Security Logging and Alerting Failures	✓ Has enabled notification integration
A10:2025	Mishandling of Exceptional Conditions	✓ Properly handle exceptional conditions

ISO 27001:2022 compliance

A brief overview of the ISO 27001 requirements and any measures taken for these.

Title	Taken measures
A.8.2 - Privileged access rights	Monitoring, not fully compliant
A.8.3 - Information access restriction	Monitoring, not fully compliant
A.8.5 - Secure authentication	Monitoring, not fully compliant
A.8.6 - Capacity management	Monitoring, not fully compliant
A.8.7 - Protection against malware	✓ Prevents unwanted write operations to filesystems ✓ Uses Lockfiles to pin code dependencies
A.8.8 - Management of technical vulnerabilities	Monitoring, not fully compliant
A.8.12 - Data leakage prevention	✓ Prevents remote code execution ✓ Has measures against SQL injection attacks ✓ Prevents XSS attacks
A.8.13 - Backups	Monitoring, not fully compliant
A.8.15 - Logging	Monitoring, not fully compliant
A.8.18 - Use of privileged utility programs	✓ Prevents the exposure of sensitive data
A.8.20 - Network security	Monitoring, not fully compliant
A.8.31 - Separation of development, test and production environments	Monitoring, not fully compliant
A.8.24 - Use of cryptography	✓ Uses secure cookies ✓ Uses up-to-date cryptographic libraries
A.8.9 - Configuration management	✓ Uses Lockfiles to pin code dependencies

A.8.16 - Monitoring activities	✓ Receives security alerts in real time
A.8.25 - Secure development lifecycle	✓ Has connected a code repository
A.8.28 - Secure coding	Monitoring, not fully compliant
A.8.32 - Change management	Monitoring, not fully compliant
A.5.15 - Access control	✓ Prevents the exposure of sensitive data
A.5.16 - Identity management	Monitoring, not fully compliant
A.5.28 - Collection of evidence	Monitoring, not fully compliant
A.5.33 - Protection of records	Monitoring, not fully compliant

Esquema Nacional de Seguridad (ENS) compliance

A brief overview of the ENS requirements and any measures taken for these.

Título	Medidas Tomadas
[op.pl.4] Planificación\Dimensionamiento - gestión de la capacidad	No se han tomado medidas activas
[op.acc.1] Control de acceso\Identificación	No se han tomado medidas activas
[op.acc.2] Control de acceso\Requisitos de acceso a la información	No se han tomado medidas activas
[op.acc.2] Control de acceso\Requisitos de acceso - programas utilitarios privilegiados.	✓ Prevenir la exposición de data sensible
[op.acc.2] Control de acceso\Requisitos de acceso - acceso a la información - mínimo privilegio	✓ Prevenir la exposición de data sensible
[op.acc.4] Control de acceso\Proceso de gestión de derechos de acceso privilegiados	No se han tomado medidas activas
[op.acc.6] Control de acceso\Mecanismo de autenticación (usuarios de la organización)	No se han tomado medidas activas
[op.exp.3] Explotación\Gestión de la configuración	✓ Usa Lockfiles para fijar dependencias de código
[op.exp.4] Explotación\Mantenimiento y actualizaciones de seguridad - Gestión de vulnerabilidades técnicas	No se han tomado medidas activas
[op.exp.5] Explotación\Gestión de cambios en sistemas y aplicaciones	No se han tomado medidas activas

[op.exp.6] Explotación\Protección frente a código dañino	✓ Prevención de operaciones de escritura no deseadas en sistemas de archivos ✓ Usa Lockfiles para fijar dependencias de código
[op.exp.8] Explotación\Registro de la actividad y eventos de seguridad	No se han tomado medidas activas
[op.exp.8] Explotación\Registro de la actividad y logs de actividad	No se han tomado medidas activas
[op.exp.9] Explotación\Registro de la gestión de incidencias - recolección de evidencia	No se han tomado medidas activas
[op.mon.3] Monitorización del sistema\Vigilancia - monitoreo de actividades y eventos de seguridad	✓ Recibe alertas de seguridad en tiempo real
[mp.com.1] Protección de las comunicaciones\Perímetro seguro - medidas de seguridad para proteger la red	No se han tomado medidas activas
[mp.si.2] Protección de los soportes de información\Criptografía	✓ Uso seguro de cookies ✓ Uso de librerías criptógraficas actualizadas
[mp.sw.1] Protección de las aplicaciones informáticas\Desarrollo de aplicaciones - separación de los entornos	No se han tomado medidas activas
[mp.sw.1] Protección de las aplicaciones informáticas\Ciclo de vida de desarrollo seguro de aplicaciones	✓ Ha conectado un repositorio de código
[mp.info.6] Protección de la información\Copias de seguridad	No se han tomado medidas activas
[mp.s.1] Protección de los servicios\correo electrónico - medidas prevenir la fuga de datos	✓ Prevención de ejecución remota de codigo ✓ Se tienen medidas para proteger contra ataques de inyección de SQL ✓ Prevención contra ataques de Cross-Site Scripting (XSS)

SOC2 compliance

A brief overview of the SOC2 requirements and any measures taken for these.

Title	Taken measures
CC3.3: Consider the potential for fraud	Monitoring, not fully compliant
CC3.2: Estimate Significance of Risks Identified	✓ Does not have any severe surface monitoring issues ✓ Does not have any severe open source dependency issues ✓ Configured monitoring for container images
CC5.2: The entity selects and develops general control activities over technology to support the achievement of objectives	✓ Does not have any severe infrastructure as code issues
CC6.1: Restricts logical access	✓ Prevents the exposure of sensitive data ✓ Has measures against SQL injection attacks ✓ Is protected against SSRF attacks ✓ Is protected against command injections attacks ✓ Prevents XSS attacks
CC6.1: Consider network segmentation	Monitoring, not fully compliant
CC6.1: Restrict access to information assets	Monitoring, not fully compliant
CC6.1: Manages credentials for infrastructure and software	Monitoring, not fully compliant
CC6.1: Use encryption to protect data	✓ Enforces encryption of data in transit ✓ Uses up to date cryptography libraries
CC6.6: Restrict Access	Monitoring, not fully compliant
CC6.6: Require additional authentication or credentials	Monitoring, not fully compliant

CC6.6: Implement boundary protection system	Monitoring, not fully compliant
CC6.7: Use encryption technologies or secure communication channels to protect data	✓ Uses up to date cryptography libraries
CC6.8: Restrict application and software installation	✓ Protects unauthorized runtime access ✓ Prevents container orchestration takeover
CC6.8: Detect unauthorized changes to software and configuration parameters	Monitoring, not fully compliant
CC6.8 Use anti-virus and anti-malware software	✓ Aikido Malware Scanner is enabled
CC7.1: Monitor infrastructure and software	✓ Connected code repositories
CC7.1: Implement change detection mechanism	Monitoring, not fully compliant
CC7.1: Detect unknown or unauthorized components	✓ Does not have risky licenses
CC7.1: Conduct vulnerability scans	✓ Uses Lockfiles to pin code dependencies ✓ Connected code repositories
CC7.1: Implement filters to analyze anomalies	✓ Connected code repositories
CC7.1: Restores the affected environments	✓ Has no critical open source dependency issues
CC8.1: Protect confidential information	✓ Prevents the exposure of sensitive data
CC8.1: Track system changes	Monitoring, not fully compliant

CC10.3: Tests integrity and completeness of backup data	Monitoring, not fully compliant

UK Cyber Essentials compliance

A brief overview of the UK Cyber Essentials requirements and any measures taken for these.

Title	Taken measures
1.1 Ensure that only safe and necessary network services can be accessed from the internet	✓ Prevents public access to file storage ✓ Prevents public access to databases ✓ Thread detection logging enabled
2.1 Ensure that computers and network devices are properly configured to reduce the level of inherent vulnerabilities	✓ Proper access management for resources ✓ Encryption at rest enabled ✓ Enforces Proper SSL usage ✓ Prevents abuse of cookies ✓ Uses up to date cryptography libraries
3.1 Ensure user accounts are assigned to authorised individuals only and provide access to the minimum necessary services	✓ Protects runtime access to cloud resources
4.1 Ensure that known malware and untrusted software are not executed	✓ No malware issues
5.1 Ensure that devices and software are not vulnerable to known security issues for which fixes are available	✓ Uses up to date cryptography libraries

CIS v8.1 Controls compliance

A brief overview of the CIS controls and any measures taken for these.

Title	Taken measures
2.2 Ensure Authorized Software is Currently Supported	Monitoring, not fully compliant
3.3 Configure Data Access Control Lists	Monitoring, not fully compliant
3.4 Enforce Data Retention	✓ Enabled security logging for cloud instances
3.10 Encrypt Sensitive Data in Transit	✓ Enforces encryption of data in transit
3.11 Encrypt Sensitive Data at Rest	✓ Encrypts data at rest
3.14 Log Sensitive Data Access	✓ Enabled security logging for cloud instances
4.4 Implement and Manage a Firewall on Servers	✓ Prevents unauthorized public access to file storage ✓ Prevents unauthorized public access to database
4.6 Securely Manage Enterprise Assets and Software	✓ Enforces latest TLS version
4.9 Configure Trusted DNS Servers on Enterprise Assets	✓ Uses DNSSEC extensions
5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts	Monitoring, not fully compliant
6.5 Require MFA for Administrative Access	Monitoring, not fully compliant
6.4 Require MFA for Remote Network Access	Monitoring, not fully compliant
7.1 Establish and Maintain a Vulnerability Management Process	Monitoring, not fully compliant

8.2 Collect Audit Logs	✓ Enabled security logging for cloud instances
10.1 Deploy and Maintain Anti-Malware Software	✓ No malware issues ✓ Prevents unwanted write operations to filesystems
11.2 Perform Automated Backups	✓ Has backups for stateful cloud resources
12.3 Securely Manage Network Infrastructure	✓ Prevents unauthorized public access to networks and instances ✓ Prevents unauthorized public access to database
12.6 Use of Secure Network Management and Communication Protocols	✓ Prevents unauthorized public access to networks and instances ✓ Enforces encryption of data in transit ✓ Uses secure communications protocols
13.6 Collect Network Traffic Flow Logs	✓ Enabled security logging for cloud instances
16.2 Establish and Maintain a Process to Accept and Address Software Vulnerabilities	Monitoring, not fully compliant
16.5 Use Up-to-Date and Trusted Third-Party Software Components	✓ No risky licenses in 3rd party dependencies
16.8 Separate Production and Non-Production Systems	Monitoring, not fully compliant
16.12 Implement Code-Level Security Checks	Monitoring, not fully compliant

CIS AWS benchmark compliance

A brief overview of the CIS AWS benchmark and any measures taken for these.

Title	Taken measures
2.3 No root user account access key exists	Monitoring, not fully compliant
2.4 MFA is enabled for the root user account	Monitoring, not fully compliant
2.7 IAM password policy requires minimum length of 14 or greater	Monitoring, not fully compliant
2.8 IAM password policy prevents password reuse	Monitoring, not fully compliant
2.9 MFA is enabled for all IAM users with console access	Monitoring, not fully compliant
2.11 Credentials unused for 45 days are disabled	Monitoring, not fully compliant
2.12 There is only one active access key per IAM user	Monitoring, not fully compliant
2.13 Access keys should be rotated every 90 days	Monitoring, not fully compliant
2.14 IAM users receive permissions only through groups	Monitoring, not fully compliant
2.15 IAM policies allowing full administrative privileges are not attached	Monitoring, not fully compliant
2.16 Support role has been created to manage incidents with AWS Support	Monitoring, not fully compliant
2.17 IAM instance roles are used for AS resources access from instances	Monitoring, not fully compliant

2.18 IAM SSL/TLS certificates are not expired	Monitoring, not fully compliant
2.19 IAM External Access Analyzer is enabled for all regions	Monitoring, not fully compliant
2.21 Access to CloudShell is restricted	Monitoring, not fully compliant
3.1.1 S3 Bucket Policy denies HTTP requests	Monitoring, not fully compliant
3.1.2 MFA delete is enabled on S3 buckets	Monitoring, not fully compliant
3.1.4 S3 is configured with 'Block Public Access' enabled	Monitoring, not fully compliant
3.2.1 RDS data is encrypted at rest	Monitoring, not fully compliant
3.2.2 'Auto Minor Version Upgrade' is enabled for RDS instances	Monitoring, not fully compliant
3.2.3 RDS instances are not publicly accessible	Monitoring, not fully compliant
3.2.4 RDS clusters use Multi-AZ for enhanced availability	Monitoring, not fully compliant
3.3.1 EFS files systems are encrypted at rest	Monitoring, not fully compliant
4.1 Cloudtrail enabled in all regions	Monitoring, not fully compliant
4.2 Cloudtrail log validation is enabled	Monitoring, not fully compliant
4.3 AWS Config enabled in all regions	Monitoring, not fully compliant
4.4 Cloudtrail logs have server access logging enabled	Monitoring, not fully compliant

4.5 Cloudtrail logs are encrypted at rest using a CMK	Monitoring, not fully compliant
4.6 Symmetric CMKs rotation is enabled	Monitoring, not fully compliant
4.7 VPC flow logging is enabled in all regions	Monitoring, not fully compliant
4.8 Ensure object-level logging for S3 write events is enabled	Monitoring, not fully compliant
4.9 Ensure object level logging for S3 read events is enabled	Monitoring, not fully compliant
6.1.1 EBS volumes are encrypted by default	Monitoring, not fully compliant
6.1.2 CIFS access is restricted to trusted networks	Monitoring, not fully compliant
6.3 Security groups do not allow ingress from 0.0.0.0/0 on server admin ports	Monitoring, not fully compliant
6.4 Security groups do not allow ingress from ::/0 on server admin ports	Monitoring, not fully compliant
6.5 Default security groups restricts all traffic	Monitoring, not fully compliant
6.7 EC2 metadata service only allows IMDSv2	Monitoring, not fully compliant

CIS Kubernetes benchmark compliance

A brief overview of the CIS Kubernetes benchmark and any measures taken for these.

Title	Taken measures
1.2.1 Ensure that the --anonymous-auth argument is set to false	Monitoring, not fully compliant
1.2.2 Ensure that the --token-auth-file parameter is not set	Monitoring, not fully compliant
1.2.3 Ensure that the --DenyServiceExternalIPs is set	Monitoring, not fully compliant
1.2.4 Ensure that the --kubelet-client-certificate and --kubelet-client-key arguments are set	Monitoring, not fully compliant
1.2.5 Ensure that the --kubelet-certificate-authority argument is set	Monitoring, not fully compliant
1.2.6 Ensure that the --authorization-mode argument is not set to AlwaysAllow	Monitoring, not fully compliant
1.2.7 Ensure that the --authorization-mode argument includes Node	Monitoring, not fully compliant
1.2.8 Ensure that the --authorization-mode argument includes RBAC	Monitoring, not fully compliant
1.2.9 Ensure that the admission control plugin EventRateLimit is set	Monitoring, not fully compliant
1.2.10 Ensure that the admission control plugin AlwaysAdmit is not set	Monitoring, not fully compliant
1.2.11 Ensure that the admission control plugin AlwaysPullImages is set	Monitoring, not fully compliant
1.2.12 Ensure that the admission control plugin ServiceAccount is set	Monitoring, not fully compliant

1.2.13 Ensure that the admission control plugin NamespaceLifecycle is set	Monitoring, not fully compliant
1.2.14 Ensure that the admission control plugin NodeRestriction is set	Monitoring, not fully compliant
1.2.15 Ensure that the --profiling argument is set to false (API Server)	Monitoring, not fully compliant
1.2.16 Ensure that the --audit-log-path argument is set	Monitoring, not fully compliant
1.2.17 Ensure that the --audit-log-maxage argument is set to 30 or as appropriate	Monitoring, not fully compliant
1.2.18 Ensure that the --audit-log-maxbackup argument is set to 10 or as appropriate	Monitoring, not fully compliant
1.2.19 Ensure that the --audit-log-maxsize argument is set to 100 or as appropriate	Monitoring, not fully compliant
1.2.20 Ensure that the --request-timeout argument is set as appropriate	Monitoring, not fully compliant
1.2.21 Ensure that the --service-account-lookup argument is set to true	Monitoring, not fully compliant
1.2.22 Ensure that the --service-account-key-file argument is set	Monitoring, not fully compliant
1.2.23 Ensure that the --etcd-certfile and --etcd-keyfile arguments are set	Monitoring, not fully compliant
1.2.24 Ensure that the --tls-cert-file and --tls-private-key-file arguments are set	Monitoring, not fully compliant

1.2.25 Ensure that the --client-ca-file argument is set	Monitoring, not fully compliant
1.2.26 Ensure that the --etcd-cafile argument is set	Monitoring, not fully compliant
1.2.29 Ensure that the API Server only makes use of Strong Cryptographic Ciphers	Monitoring, not fully compliant
1.3.1 Ensure that the --terminated-pod-gc-threshold argument is set	Monitoring, not fully compliant
1.3.2 Ensure that the --profiling argument is set to false (Controller Manager)	Monitoring, not fully compliant
1.3.3 Ensure that the --use-service-account-credentials argument is set to true	Monitoring, not fully compliant
1.3.4 Ensure that the --service-account-private-key-file argument is set	Monitoring, not fully compliant
1.3.5 Ensure that the --root-ca-file argument is set	Monitoring, not fully compliant
1.3.6 Ensure that the RotateKubeletServerCertificate argument is set to true	Monitoring, not fully compliant
1.3.7 Ensure that the --bind-address argument is set to 127.0.0.1 (Controller Manager)	Monitoring, not fully compliant
1.4.1 Ensure that the --profiling argument is set to false (Scheduler)	Monitoring, not fully compliant
1.4.2 Ensure that the --bind-address argument is set to 127.0.0.1 (Scheduler)	Monitoring, not fully compliant

2.1 Ensure that the --cert-file and --key-file arguments are set	Monitoring, not fully compliant
2.2 Ensure that the --client-cert-auth argument is set to true	Monitoring, not fully compliant
2.3 Ensure that the --auto-tls argument is not set to true	Monitoring, not fully compliant
2.4 Ensure that the --peer-cert-file and --peer-key-file arguments are set	Monitoring, not fully compliant
2.5 Ensure that the --peer-client-cert-auth argument is set to true	Monitoring, not fully compliant
2.6 Ensure that the --peer-auto-tls argument is not set to true	Monitoring, not fully compliant
2.7 Ensure that a unique Certificate Authority is used for etcd	Monitoring, not fully compliant
3.2.1 Ensure that a minimal audit policy is created	Monitoring, not fully compliant
5.1.1 Ensure that the cluster-admin role is only used where required	Monitoring, not fully compliant
5.1.3 Minimize wildcard use in Roles and ClusterRoles	Monitoring, not fully compliant
5.1.4 Minimize access to create pods	Monitoring, not fully compliant
5.1.5 Ensure that default service accounts are not actively used	Monitoring, not fully compliant
5.1.6 Ensure that Service Account Tokens are only mounted where necessary	Monitoring, not fully compliant
5.1.8 Limit use of the Bind, Impersonate and Escalate permissions	Monitoring, not fully compliant

5.1.9 Minimize access to create persistent volumes	Monitoring, not fully compliant
5.1.10 Minimize access to the proxy sub-resource of nodes	Monitoring, not fully compliant
5.1.11 Minimize access to the approval sub-resource of certificatesigningrequests	Monitoring, not fully compliant
5.1.12 Minimize access to webhook configuration objects	Monitoring, not fully compliant
5.1.13 Minimize access to the service account token creation	Monitoring, not fully compliant
5.2.1 Ensure cluster has at least one active policy control mechanism	Monitoring, not fully compliant
5.2.2 Minimize the admission of privileged containers	Monitoring, not fully compliant
5.2.3 Minimize the admission of containers sharing the host process ID namespace	Monitoring, not fully compliant
5.2.4 Minimize the admission of containers sharing the host IPC namespace	Monitoring, not fully compliant
5.2.5 Minimize the admission of containers sharing the host network namespace	Monitoring, not fully compliant
5.2.6 Minimize the admission of containers with allowPrivilegeEscalation	Monitoring, not fully compliant
5.2.7 Minimize the admission of root containers	Monitoring, not fully compliant

5.2.8 Minimize the admission of containers with the NET_RAW capability	Monitoring, not fully compliant
5.2.9 Minimize the admission of containers with capabilities assigned	Monitoring, not fully compliant
5.2.10 Minimize the admission of Windows HostProcess Containers	Monitoring, not fully compliant
5.2.11 Minimize the admission of HostPath volumes	Monitoring, not fully compliant
5.2.12 Minimize the admission of containers which use HostPorts	Monitoring, not fully compliant
5.3.2 Ensure all Namespaces have Network Policies defined	Monitoring, not fully compliant
5.4.1 Prefer using secrets as files over secrets as environment variables	Monitoring, not fully compliant
5.6.2 Ensure that the seccomp profile is set to docker/default in pod definitions	Monitoring, not fully compliant
5.6.4 The default namespace should not be used	Monitoring, not fully compliant

NIS2 compliance

A brief overview of the NIS2 directive and any measures taken for these.

Title	Taken measures
Policies on risk analysis and information system security	✓ Configured monitoring for code repositories
Incident handling	Monitoring, not fully compliant
Business continuity	Monitoring, not fully compliant
Supply chain security	Monitoring, not fully compliant
Security in network and information systems acquisition	Monitoring, not fully compliant
Policies and procedures regarding the use of cryptography	✓ Uses secure cookies ✓ Uses up-to-date cryptographic libraries
Access control policies and asset management	Monitoring, not fully compliant
The use of multi-factor authentication	Monitoring, not fully compliant

NIST 800-53 compliance

A brief overview of the NIST directive and any measures taken for these.

Title	Taken measures
1.2.4 Account Management | Disable Accounts	Monitoring, not fully compliant
1.2.5 Account Management | Automated Audit Actions	Monitoring, not fully compliant
1.2.8 Account Management | Privileged User Accounts	Monitoring, not fully compliant
1.2.13 Account Management | Account Monitoring for Atypical Usage	Monitoring, not fully compliant
1.3.8 Access Enforcement | Role-based access control	Monitoring, not fully compliant
1.4.22 Information Flow Enforcement | Physical or Logical Separation of Information Flows	✓ Enforces safe SSL protocol usage ✓ Prevents abuse of cookies ✓ Uses up to date cryptography libraries
1.6.2 Least Privilege | Authorize Access to Security Functions	✓ Enforces safe SSL protocol usage
1.17.2 Remote Access | Monitoring and Control	Monitoring, not fully compliant
1.17.6 Remote Access | Monitoring for Unauthorized Connections	Monitoring, not fully compliant
1.23.1 Data Mining Protection	✓ Restrict excessive or unauthorized data mining queries.
3.6.2 Audit Record Review, Analysis, and Reporting | Automated Process Integration	✓ Limit access to sensitive data based on user roles and responsibilities.

3.9.4 Protection of Audit Information | Cryptographic Protection	✓ Enforces safe SSL protocol usage ✓ Prevents abuse of cookies
3.9.5 Protection of Audit Information | Access by Subset of Privileged Users	Monitoring, not fully compliant
3.11.2 Audit Record Retention | Long-term Retrieval Capability	Monitoring, not fully compliant
3.12.2 Audit Record Generation | System-wide and Time-correlated Audit Trail	Monitoring, not fully compliant
4.7.7 Continuous Monitoring | Automation Support for Monitoring	✓ Has email notifications set up
5.5.2 Access Restrictions for Change | Automated Access Enforcement and Audit Records	✓ Enforces safe SSL protocol usage
5.7.9 Least Functionality | Binary or Machine Executable Code	Monitoring, not fully compliant
6.9.6 System Backup | Transfer to Alternate Storage Site	Monitoring, not fully compliant
7.2.2 Identification and Authentication (organizational Users) | Multi-factor Authentication to Privileged Accounts	Monitoring, not fully compliant
7.2.3 Identification and Authentication (organizational Users) | Multi-factor Authentication to Non-privileged Accounts	Monitoring, not fully compliant
7.5.2 Authenticator Management | Password-based Authentication	Monitoring, not fully compliant
7.5.7 Authenticator Management | Protection of Authenticators	Monitoring, not fully compliant
7.10.1 Adaptive Authentication	Monitoring, not fully compliant

8.5.2 Incident Monitoring | Automated Tracking, Data Collection, and Analysis	Monitoring, not fully compliant
13.12.1 Insider Threat Program	✓ Enforces safe SSL protocol usage
16.10.1 Threat Hunting	Monitoring, not fully compliant
17.3.2 System Development Life Cycle | Manage Preproduction Environment	✓ Enforces safe SSL protocol usage ✓ Prevents abuse of cookies ✓ Uses up to date cryptography libraries
18.5.2 Denial-of-service Protection | Restrict Ability to Attack Other Systems	Monitoring, not fully compliant
18.5.3 Denial-of-service Protection | Capacity, Bandwidth, and Redundancy	✓ Enforces safe SSL protocol usage
18.7.6 Boundary Protection | Deny by Default Allow by Exception	✓ Enforces safe SSL protocol usage ✓ Prevents abuse of cookies
18.7.8 Boundary Protection | Split Tunneling for Remote Devices	Monitoring, not fully compliant
18.7.11 Boundary Protection | Prevent Exfiltration	✓ Restrict excessive or unauthorized data mining queries. ✓ Enforces safe SSL protocol usage
18.7.16 Boundary Protection | Networked Privileged Accesses	Monitoring, not fully compliant
18.12.2 Cryptographic Key Establishment and Management | Availability	✓ Enforces safe SSL protocol usage
18.16.3 Transmission of Security and Privacy Attributes | Anti-spoofing Mechanisms	Monitoring, not fully compliant

18.16.4 Transmission of Security and Privacy Attributes | Cryptographic Binding	✓ Enforces safe SSL protocol usage
18.20.3 Secure Name/address Resolution Service (authoritative Source) | Data Origin and Integrity	Monitoring, not fully compliant
18.21.2 Secure Name/address Resolution Service (recursive or Caching Resolver) | Data Origin and Integrity	Monitoring, not fully compliant
18.22.1 Architecture and Provisioning for Name/address Resolution Service	Monitoring, not fully compliant
18.23.4 Session Authenticity | Unique System-generated Session Identifiers	Monitoring, not fully compliant
18.24.1 Fail in Known State	Monitoring, not fully compliant
18.28.2 Protection of Information at Rest | Cryptographic Protection	✓ Enforces safe SSL protocol usage ✓ Prevents abuse of cookies
18.34.2 Non-modifiable Executable Programs | No Writable Storage	Monitoring, not fully compliant

PCI compliance

A brief overview of the PCI Data Security Standards and any measures taken for these.

Title	Taken measures
1.2 Network security controls (NSCs) are configured and maintained.	Monitoring, not fully compliant
1.3 Network access to and from the cardholder data environment is restricted.	✓ Enforces connections to use the latest SSL version ✓ Prevents abuse of cookies
3.4 Access to displays of full PAN and ability to copy cardholder data are restricted.	Monitoring, not fully compliant
3.5 Primary account number (PAN) is secured wherever it is stored.	Monitoring, not fully compliant
4.2 PAN is protected with strong cryptography during transmission.	✓ Enforces connections to use the latest SSL version ✓ Prevents abuse of cookies ✓ Enforces encryption of data in transit
5.2 Malicious software (malware) is prevented, or detected and addressed.	✓ No malware issues
6.2.4 Develop secure coding practices.	Monitoring, not fully compliant
6.3.3 Applicable security patches and updates are installed.	Monitoring, not fully compliant
6.4 Public-facing web applications are protected against attacks.	✓ App scanned for SQL injection attack ✓ Prevents remote code execution ✓ Prevents CSRF attacks ✓ Prevents Cross Site Scripting (XSS)
7.2.2 Access is assigned to users, including privileged users.	Monitoring, not fully compliant

7.2.5 All application and system accounts and related access privileges are assigned and managed.	Monitoring, not fully compliant
7.3 Access to system components and data is managed via an access control system(s).	Monitoring, not fully compliant
8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE.	Monitoring, not fully compliant
10.2.1 Audit logs are enabled and active for all system components and cardholder data.	Monitoring, not fully compliant
10.3.3 Audit log files are promptly backed up to a secure, central, internal log server(s).	Monitoring, not fully compliant
10.7.2 Failures of critical security control systems are detected, alerted, and addressed promptly.	✓ Receives security alerts in real time
11.3.2 External vulnerability scans are performed.	Monitoring, not fully compliant
11.3.1 Internal vulnerability scans are performed.	✓ Configured monitoring for code repositories ✓ Configured monitoring for container images

HIPAA compliance

A brief overview of the HIPAA Compliance Checklist and any measures taken for these.

Title	Taken measures
1.3.1 Security Standards: General Requirements	✓ Enforces safe SSL protocol usage ✓ Prevents abuse of cookies ✓ Uses up to date cryptography libraries
1.4.1 Administrative Safeguards: Security management process	Monitoring, not fully compliant
1.4.4 Administrative Safeguards: Information access management	Monitoring, not fully compliant
1.4.5 Administrative Safeguards: Security awareness and training	Monitoring, not fully compliant
1.4.7 Administrative Safeguards: Contingency plan	Monitoring, not fully compliant
1.6.1 Technical Safeguards: Access control	Monitoring, not fully compliant
1.6.2 Technical Safeguards: Audit controls	Monitoring, not fully compliant
1.6.3 Technical Safeguards: Integrity	✓ Uses up to date cryptography libraries
1.6.4 Technical Safeguards: Person or entity authentication	Monitoring, not fully compliant
1.6.5 Technical Safeguards: Transmission Security	✓ Uses up to date cryptography libraries ✓ Enforces safe SSL protocol usage ✓ Prevents abuse of cookies

HITRUST LVL3 Compliance

A brief overview of the HITRUST LVL3 framework and any measures taken for these.

Title	Taken measures
2.3 Privilege Management	Monitoring, not fully compliant
2.4 User Password Management	✓ Prevents Exposed Secrets
2.9 User Authentication for External Connections	Monitoring, not fully compliant
2.10 Equipment Identification in Networks	Monitoring, not fully compliant
2.11 Remote Diagnostic and Configuration Port Protection	Monitoring, not fully compliant
2.12 Segregation in Networks	Monitoring, not fully compliant
2.13 Network Connection Control	✓ Use of Cryptography: Enforces SSL
2.14 Networking Routing Control	Monitoring, not fully compliant
2.16 Secure Log-on Procedures	✓ Use of Cryptography: Secure Cookies ✓ Use of Cryptography: Enforces SSL
2.17 User Identification and Authentication	Monitoring, not fully compliant
2.18 Password Management System	✓ Prevents Exposed Secrets
2.22 Information Access restriction	✓ Prevents SQL Injection Attacks ✓ Prevents Remote Code Execution Attacks ✓ Prevents CSRF Attacks ✓ Prevents Cross-Site Scripting Attacks
2.23 Sensitive System Isolation	Monitoring, not fully compliant

7.3 Protection of Organizational Records	✓ Prevents Exposed Secrets ✓ Prevents SQL Injection Attacks ✓ Prevent Root Access
7.4 Data Protection and Privacy of Covered Information	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography: Secure Cookies ✓ Prevents SQL Injection Attacks ✓ Prevent Root Access
7.6 Regulation of Cryptographic Controls	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography: Secure Cookies ✓ Use of Cryptography Libraries
10.12 Back-up	Monitoring, not fully compliant
10.13 Network Controls	Monitoring, not fully compliant
10.17 Information Handling Procedures	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography: Secure Cookies ✓ Use of Cryptography Libraries
10.18 Security of System Documentation	✓ Configured Monitoring for Code Repositories
10.19 Information Exchange Policies and Procedures	✓ Use of Cryptography: Enforces SSL
10.26 Publicly Available Information	Monitoring, not fully compliant
10.27 Audit Logging	Monitoring, not fully compliant
11.2 Input Data Validation	✓ Prevents SQL Injection Attacks ✓ Cross-Site Scripting (XSS) Prevention ✓ Server-Side Request Forgery (SSRF) Prevention
11.6 Policy on the Use of Cryptographic Controls	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography Libraries

11.7 Key Management	✓ Prevents Exposed Secrets
11.8 Control of Operational Software	✓ No Open End-of-Life (EOL) Issues ✓ No Open DAST Issues ✓ No Open OSS Security Issues ✓ Configured Monitoring for Code Repositories ✓ Configured Monitoring for Containers
11.12 Outsourced Software Development	✓ No Open SCM Security Issues
11.13 Control of Technical Vulnerabilities	Monitoring, not fully compliant

GDPR compliance

A brief overview of GDPR rules and any measures taken for these.

Title	Taken measures
2.1 Principles Relating to Processing of Personal Data	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography: Secure Cookies ✓ Use of Cryptography Libraries
4.2 Data Protection by Design	Monitoring, not fully compliant
4.5 Processor	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography: Secure Cookies ✓ Use of Cryptography Libraries
4.7 Records of Processing Activities	Monitoring, not fully compliant
4.9 Security of Processing	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography: Secure Cookies ✓ Use of Cryptography Libraries

DORA compliance

A brief overview of the DORA Compliance Checklist and any measures taken for these.

Title	Taken measures
Article 7, ICT Risk Management: Systems, Protocols, and Tools	Monitoring, not fully compliant
Article 8, ICT Risk Management: Identification	✓ Has connected code repositories
Article 9, ICT Risk Management: Protection and prevention	✓ Use of Cryptography: Enforces SSL ✓ Use of Cryptography: Secure Cookies
Article 10, ICT Risk Management: Detection	Monitoring, not fully compliant
Article 11, ICT Risk Management: Response and Recovery	✓ Has email notifications set up
Article 12, ICT Risk Management: Backup	Monitoring, not fully compliant
Article 15, Harmonization With Other Regulations	Monitoring, not fully compliant
Article 17, Incident Management Process	✓ Has email notifications set up
Article 18, Classification of Incidents and Cyber Threats	✓ Configured monitoring for code repositories ✓ Configured monitoring for container images

Scan history report

This section details all company assets that are being monitored and how often scans are performed.

Kind	Frequency	Last occurence
Open-source dependencies: • 70 dart packages monitored • 25 python packages monitored	Daily	2026-11-08
OSS licenses: 95 monitored for compliance	Weekly	2026-11-08
Static app security testing: 1 repository monitored	Daily	2026-11-08
Infrastructure as code: monitored for misconfigurations	Daily	2026-11-08
Exposed secrets: history of 1 repository scanned	Daily	2026-11-08

Issue insights over the past 3 months

The table below gives an overview of new findings in a 3 month rolling window. A triaged finding is one that has been either been solved, ignored after analysis or planned in a task management system for resolution.

Issue kind	New	False positives	Handled
Open-source Dependencies	2	1	1
Container Images	0	0	0
Cloud Configurations	0	0	0
Virtual Machines	0	0	0
Secrets in source code history	0	0	0
DAST/Surface Monitoring	0	0	0
SAST/Static App Security Testing	0	0	0
Infrastructure As Code	0	0	0
Mobile	6	0	3
End-of-life Runtimes	0	0	0
Access Controls	0	0	0
Licenses	0	0	0
Malware Issues	0	0	0
AI Pentest Issues	18	0	2

Open Issues Snapshot

The table below gives an overview of all findings that were open Nov 8th 2026.

Issue type	Critical	High	Medium	Low
Open-source Dependencies	0	0	0	0
Container Images	0	0	0	0
Cloud Configurations	0	0	0	0
Virtual Machines	0	0	0	0
Secrets in source code history	0	0	0	0
DAST/Surface Monitoring	0	0	0	0
SAST/Static App Security Testing	0	0	0	0
Infrastructure As Code	0	0	0	0
Mobile	0	1	2	0
End-of-life Runtimes	0	0	0	0
Access Controls	0	0	0	0
Licenses	0	0	0	0
Malware Issues	0	0	0	0
AI Pentest Issues	0	0	0	0
agentic_review	0	0	12	4